

Testing For Bypassing Authorization Schema

when Test this ask this

Is it possible to access that resource even if the user is not authenticated ?

Is it possible to access that resource after the log out ?

Is it possible to access functions and resources that should be accessible to a user that holds a different role or privilege ?

check roles in application if there user and admin accounts try test

Is it possible to access admin functions by user account ?

★ Test Objectives

Access if horizontal or vertical access is possible

★ Testing for Horizontal Bypassing Authorization schema

for every function , specific role , request that application executes verify this

Is it possible to access resources or operate functions to another user account with same role or privilege ?

1-Register two users with different privileges.

2-keep different sessions active

3-for every request change the relevant parameters and the session identifier from token one to token two and diagnose the responses for each token

the application is vulnerable if the response the same , contain same private data for other users' resource or data.

Test for access to resources assigned to a different role

For each role:

Test for special request header handling

[X-Original-URL , X-Rewrite-URL] this leveraged in a situation in which application is behind a component that applies access control restriction based on the request URL

example: GET /admin HTTP/1.1

use GET * HTTP/1.1

X-Original-URL:/admin

send a request with : X-Original-URL : /donotexist2

if return " resource not found " this indicates that the application supports the special request headers

Other Headers to consider

Headers:
X-Forwarded-For
X-Forward-For
X-Remote-IP
X-Originating-IP
X-Remote-Addr
X-Client-IP

Values
127.0.0.1 (or anything in the 127.0.0.0/8 or ::1/128 address spaces)
localhost
Any RFC1918 address:
10.0.0.0/8
172.16.0.0/12
192.168.0.0/16
Link local addresses: 169.254.0.0/16 / 127.0.0.4:80 or 443 or 43982